

XLOADER (FORMBOOK) INFECTION

STATIC MALWARE ANALYSIS

Introduction

XLoader is a successor to the Formbook malware, is a sophisticated stealer targeting Windows and macOS systems. It is commonly spread through email attachments and operates as a Malware-as-a-Service (MaaS).

There are several characteristics to the infection:

- XLoader harvests credentials from web browsers, email clients, and FTP applications
- It can record keystrokes, capture screenshots, and access clipboard
- It can download and execute malicious files, from a C2 server.

Methodology

For the packet capture file I took it from [packet-capture-analysis.net](https://www.packet-capture-analysis.net) which is a repository of a lot of packet captures already ready to be analyzed. It can be found and downloaded specifically using the link below:

<https://www.malware-traffic-analysis.net/2026/04/13/index.html>

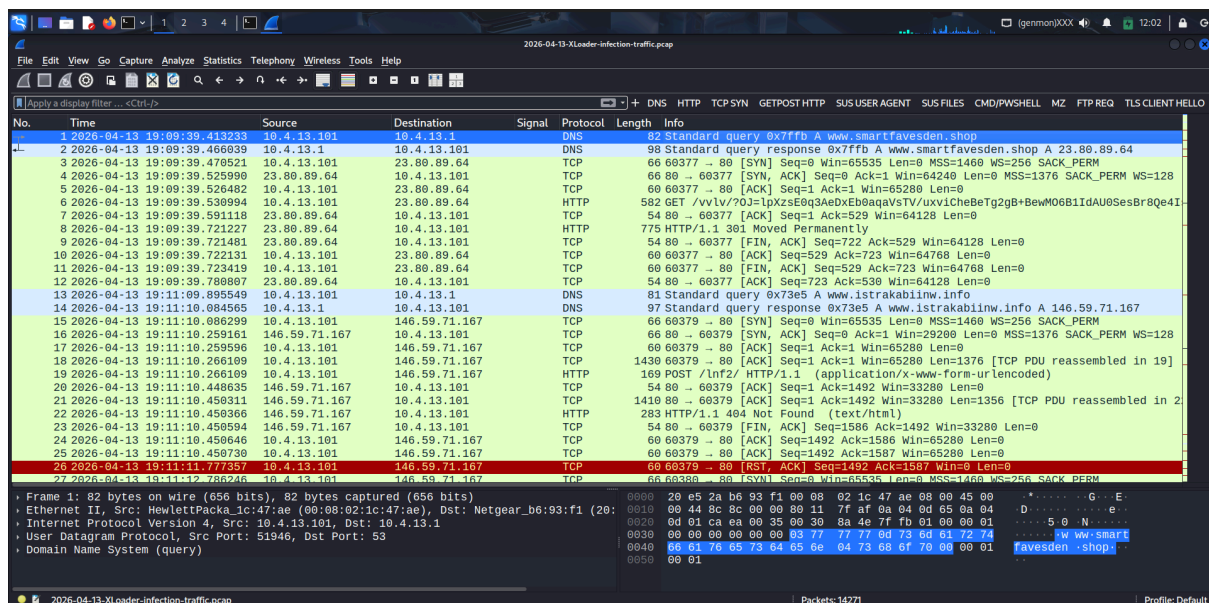
The main tool I will use, since this is a packet capture file, will be Wireshark and I also used Virus Total to check malicious content found within the packet capture. And the password to crack this zip file is infected_20260413.

To do this project, I did not extract any files or executables from this packet capture for the safety of my network and machine, since this is actual malware and there are actually malicious files inside the packet capture.

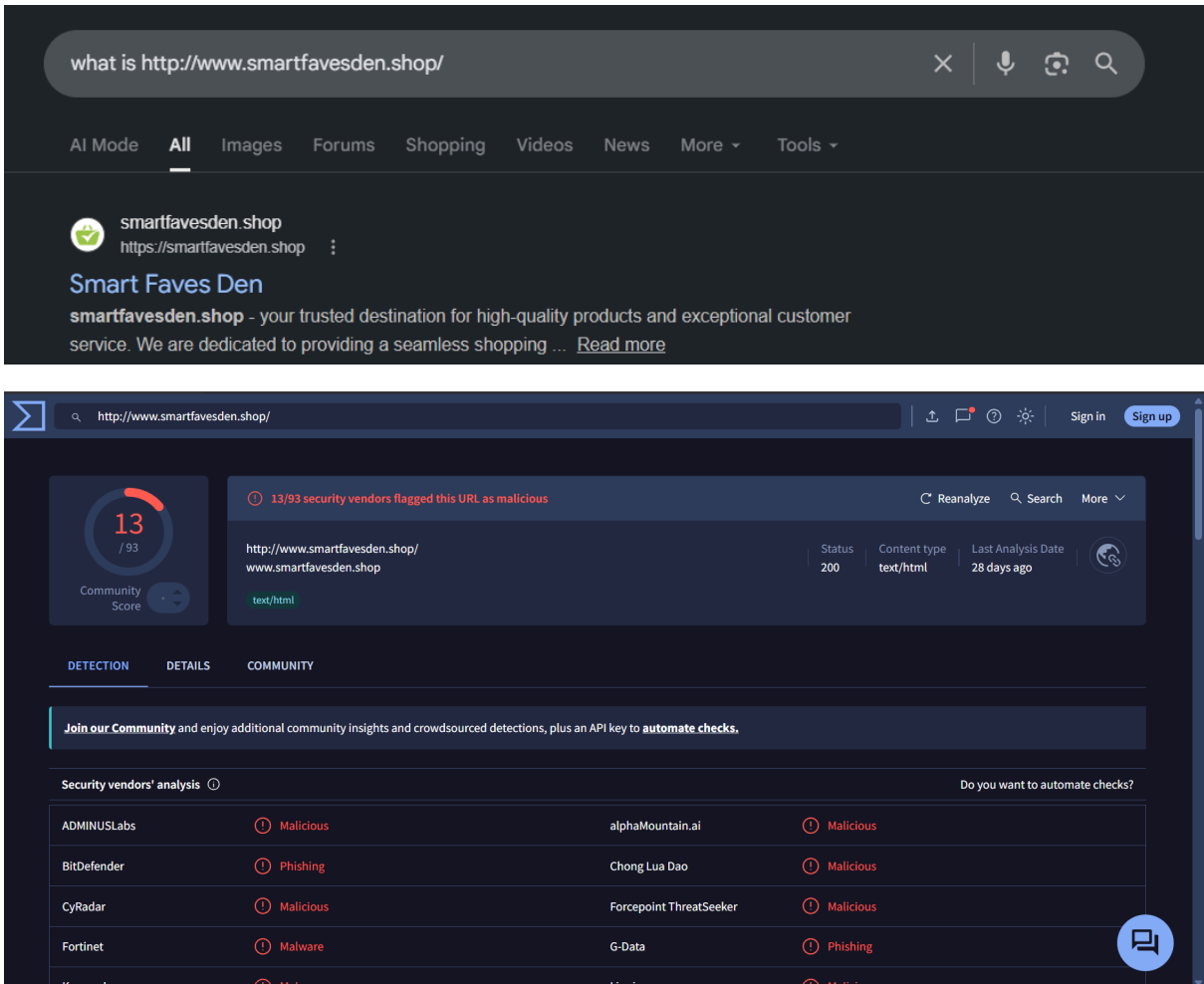
Results

```
(rafael@raf)-[~/PACKET_CAPTURES]
$ capinfos 2026-04-13-XLoader-infection-traffic.pcap
File name: 2026-04-13-XLoader-infection-traffic.pcap
File type: Wireshark/tcpdump/... - pcap
File encapsulation: Ethernet
File timestamp precision: microseconds (6)
Packet size limit: file hdr: 65535 bytes
Number of packets: 14 k
File size: 10 MB
Data size: 10 MB
Capture duration: 1137.078329 seconds
Earliest packet time: 2026-04-14 03:09:39.413233
Latest packet time: 2026-04-14 03:28:36.491562
Data byte rate: 9,198 bytes/s
Data bit rate: 73 kbps
Average packet size: 732.94 bytes
Average packet rate: 12 packets/s
SHA256: 482a9c90793565dd1be62e4212bbc3af07bdaa6577296e3220c87e5c2aa2d070
SHA1: 2e9751a4c97141a34e7474d4414b31646f4e4810
Strict time order: True
Number of interfaces in file: 1
Interface #0 info:
Encapsulation = Ethernet (1 - ether)
Capture length = 65535
Time precision = microseconds (6)
Time ticks per second = 1000000
Number of stat entries = 0
Number of packets = 14271
```

Here I run a capinfos on the PCAP file, and it was recorded for 1137 seconds, which is about 18 minutes and 57 seconds. And the SHA256 value for this PCAP is 482a9c90793565dd1be62e4212bbc3af07bdaa6577296e3220c87e5c2aa2d070



First we see in the first 2 packets that the client 10.4.13.101 made a DNS request and got a response from www.smartfavesden.shop and when I Google it, it is an-e-commerce platform like shown by the screenshot below.



However after, scanning it on Virus Total, we see that the domain is malicious and the malware is obtained from that website.

6	2026-04-13	19:09:39.530994	10.4.13.101	23.80.89.64	HTTP	582 GET /vvlv/?0j=lpXzsE0q3AeBxEb8aqaVsTV/uxviCheBeTg2gB+BewM0681IdA
7	2026-04-13	19:09:39.591118	23.80.89.64	10.4.13.101	TCP	54 80 -> 60377 [ACK] Seq=1 Ack=529 Win=64128 Len=0
8	2026-04-13	19:09:39.721227	23.80.89.64	10.4.13.101	HTTP	775 HTTP/1.1 301 Moved Permanently
9	2026-04-13	19:09:39.721481	23.80.89.64	10.4.13.101	TCP	54 80 -> 60377 [FIN, ACK] Seq=722 Ack=529 Win=64128 Len=0
10	2026-04-13	19:09:39.722131	10.4.13.101	23.80.89.64	TCP	60 60377 -> 80 [ACK] Seq=529 Ack=723 Win=64768 Len=0
11	2026-04-13	19:09:39.723419	10.4.13.101	23.80.89.64	TCP	60 60377 -> 80 [FIN, ACK] Seq=529 Ack=723 Win=64768 Len=0
12	2026-04-13	19:09:39.780807	23.80.89.64	10.4.13.101	TCP	54 80 -> 60377 [ACK] Seq=723 Ack=530 Win=64128 Len=0
13	2026-04-13	19:11:09.895549	10.4.13.101	10.4.13.1	DNS	81 Standard query 0x73e5 A www.istrakabiinw.info
14	2026-04-13	19:11:10.084565	10.4.13.1	10.4.13.101	DNS	97 Standard query response 0x73e5 A www.istrakabiinw.info A 146.59.

And then we see it making a GET request but gets a response of 301, meaning it has been moved permanently, and then it moved and makes DNS query to www.istrakabiinw.info

Community Score

11 / 92

11/92 security vendors flagged this URL as malicious

Reanalyze Search More

http://www.istrakabiinw.info/

Status 503 Content type text/html Last Analysis Date 1 hour ago

text/html external-resources

DETECTION

DETAILS

COMMUNITY

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Security vendors' analysis

Do you want to automate checks?

ADMINUSLabs	Malicious	alphaMountain.ai	Phishing
BitDefender	Phishing	Chong Lua Dao	Malicious
CyRadar	Phishing	Forcepoint ThreatSeeker	Malicious
Fortinet	Malware	G-Data	Phishing

And when I put www.istrakabiinw.info in Virus Total, it also flagged it as malicious. This could be a domain that is randomly generated and a technique called Domain Generation Algorithm (DGA).

19/02/2024-04-13	19:11:11.10.260199	10.4.13.101	146.59.71.167	HTTP	169 POST [in/7z HTTP/1.1] (application/x-www-form-urlencoded)
20/02/2024-04-13	19:11:11.10.448635	146.59.71.167	10.4.13.101	TCP	54 80 → 60379 [ACK] Seq=1 Ack=1492 Win=33280 Len=0
21/02/2024-04-13	19:11:11.10.450311	146.59.71.167	10.4.13.101	TCP	1410 80 → 60379 [ACK] Seq=1 Ack=1492 Win=33280 Len=1356 [TCP PDU reas
22/02/2024-04-13	19:11:11.10.450366	146.59.71.167	10.4.13.101	HTTP	200 GET /1.1_404 Not Found (text/html)

Then

Ethernet - 1	IPv4 - 29	TCP - 303	UDP - 28									
Address A	Address B	Packets	Bytes	Stream ID	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A	Rel Start	Duration	Bits/s A → B	Bits/s B → A
10.4.13.101	3.33.251.168	891	672 kb	6	535	648 kb	356	23 kb	196.106544	935.3321	5,546 bits/s	198 bits/s
10.4.13.101	8.217.99.246	496	331 kb	17	252	304 kb	24	27 kb	751.814115	22.7924	106 kbps	9,381 bits/s
10.4.13.101	10.4.13.1	58	5 kb	0	29	2 kb	29	3 kb	0.000000	1093.9151	16 bits/s	22 bits/s
10.4.13.101	15.197.225.128	11	1 kb	24	5	831 bytes	6	469 bytes	999.309948	0.1516	43 kbps	24 kbps
10.4.13.101	18.201.116.200	1,306	981 kb	8	766	914 kb	540	66 kb	249.389413	798.1055	9,165 bits/s	662 bits/s
10.4.13.101	23.80.89.64	50	9 kb	1	25	4 kb	25	5 kb	0.057288	1104.9923	29 bits/s	36 bits/s
10.4.13.101	31.192.212.202	12	3 kb	27	6	888 bytes	6	2 kb	1077.507077	0.5567	82 kbps	26 kbps
10.4.13.101	37.140.192.56	857	818 kb	21	286	18 kb	571	801 kb	948.189497	1.7232	12 kbps	3,716 kbps
10.4.13.101	47.76.53.129	980	652 kb	7	519	611 kb	461	42 kb	221.815996	915.2623	5,340 bits/s	362 bits/s
10.4.13.101	47.109.65.195	10	2 kb	22	5	827 bytes	5	1 kb	955.029774	0.8826	7,495 bits/s	9,118 bits/s
10.4.13.101	66.29.132.129	451	372 kb	11	269	309 kb	182	63 kb	332.845716	21.4198	115 kbps	23 kbps
10.4.13.101	66.29.152.174	888	648 kb	3	519	611 kb	369	37 kb	117.927211	997.8381	4,498 bits/s	294 bits/s
10.4.13.101	68.65.121.158	405	320 kb	19	255	309 kb	150	11 kb	805.173087	21.6169	114 kbps	4,110 bits/s
10.4.13.101	81.2.196.19	841	637 kb	9	514	610 kb	327	26 kb	276.405526	776.4597	6,287 bits/s	271 bits/s
10.4.13.101	81.177.140.179	10	2 kb	23	5	828 bytes	5	1 kb	960.969702	0.5976	11 kbps	14 kbps
10.4.13.101	85.159.66.93	10	2 kb	26	6	889 bytes	4	664 bytes	1072.027114	0.6022	11 kbps	8,821 bits/s
10.4.13.101	87.236.16.114	485	322 kb	14	252	304 kb	233	18 kb	414.266355	22.4570	108 kbps	6,389 bits/s
10.4.13.101	95.163.244.138	881	646 kb	10	523	612 kb	358	34 kb	303.667154	785.3727	6,231 bits/s	350 bits/s
10.4.13.101	103.106.105.35	543	388 kb	13	262	305 kb	281	83 kb	384.896973	24.2676	100 kbps	27 kbps
10.4.13.101	104.21.62.145	960	704 kb	5	519	611 kb	441	93 kb	170.259811	956.0588	5,111 bits/s	778 bits/s
10.4.13.101	146.59.71.167	1,057	686 kb	2	533	612 kb	524	74 kb	90.673066	1019.8711	4,801 bits/s	579 bits/s
10.4.13.101	172.67.154.38	473	318 kb	12	244	304 kb	169	14 kb	359.233890	20.9162	116 kbps	5,438 bits/s
10.4.13.101	172.67.200.120	13	3 kb	28	5	880 bytes	7	2 kb	1093.917346	0.7673	9,175 bits/s	19 kbps
10.4.13.101	172.67.203.88	12	3 kb	25	6	827 bytes	7	2 kb	1066.402327	0.4226	15 kbps	40 kbps
10.4.13.101	172.67.211.213	447	327 kb	18	251	304 kb	196	23 kb	779.458502	20.9670	116 kbps	8,834 bits/s
10.4.13.101	185.135.132.97	446	327 kb	15	253	304 kb	193	22 kb	441.841113	21.9065	111 kbps	8,081 bits/s
10.4.13.101	195.110.124.133	459	322 kb	16	267	307 kb	192	15 kb	468.788205	631.0502	3,891 bits/s	188 bits/s
10.4.13.101	195.161.62.100	474	323 kb	20	252	304 kb	222	18 kb	858.596677	22.4173	108 kbps	6,589 bits/s
10.4.13.101	206.41.74.19	805	637 kb	4	519	611 kb	286	26 kb	144.312446	976.5516	5,005 bits/s	211 bits/s

The screenshot shows the Wireshark interface with the 'Conversations' pane selected. It displays a list of network flows. The first column is 'Address A' (10.4.13.101), the second is 'Port A' (80), the third is 'Address B' (various external IPs), and the fourth is 'Port B' (80). The 'Packets' column shows the number of packets in each flow, and the 'Bytes' column shows the total bytes transferred. The 'Stream ID' column identifies the TCP stream. The 'Packets A → B' and 'Bytes A → B' columns show the data sent from the client to the server. The 'Packets B → A' and 'Bytes B → A' columns show the data received by the client from the server. The 'Rel Start' column shows the relative start time of the flow, and the 'Duration' column shows the total duration of the flow. The 'Bits/s A → B' and 'Bits/s B → A' columns show the average data rate in bits per second. The 'Flows' column shows the number of flows for each destination. The 'Filter list for specific type' column shows the filter applied to the list.

Address A	Port A	Address B	Port B	Packets	Bytes	Stream ID	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A	Rel Start	Duration	Bits/s A → B	Bits/s B → A	Flows
10.4.13.101	80	60516	80	10	148	135	5	830 bytes	5	645 bytes	490.325389	0.4830	13 kbps	10 kbps	2
10.4.13.101	80	59548	80	11	348	254	6	218	5	962 bytes	858.586677	1.6977	8,637 bits/s	4,533 bits/s	3
10.4.13.101	80	59549	80	13	648	255	8	518	5	962 bytes	861.297478	1.7145	22 kbps	4,488 bits/s	5
10.4.13.101	80	59550	80	12	548	256	7	418	5	962 bytes	864.025814	1.7211	18 kbps	4,471 bits/s	4
10.4.13.101	80	59551	80	10	348	257	6	218	4	908 bytes	866.760438	1.7284	8,262 bits/s	4,202 bits/s	3
10.4.13.101	80	59552	80	104	7648	258	55	73 kB	49	3 kB	869.502912	1.7160	339 kbps	15 kbps	52
10.4.13.101	80	59553	80	105	7648	259	55	73 kB	50	3 kB	872.229929	1.7224	338 kbps	15 kbps	52
10.4.13.101	80	59554	80	105	7648	260	55	73 kB	50	3 kB	874.962725	1.7274	337 kbps	15 kbps	52
10.4.13.101	80	59555	80	105	7648	261	55	73 kB	50	3 kB	877.701612	1.7178	338 kbps	15 kbps	52
10.4.13.101	80	59556	80	9	248	262	5	822 bytes	4	1 kB	880.432946	0.5811	11 kbps	15 kbps	2
10.4.13.101	80	59557	80	10	248	267	5	822 bytes	5	880 bytes	907.211119	0.2124	30 kbps	33 kbps	2
10.4.13.101	80	59558	80	10	248	263	5	822 bytes	5	880 bytes	1025.743469	0.2023	32 kbps	34 kbps	2
10.4.13.101	80	59559	80	10	248	299	5	822 bytes	5	880 bytes	1120.662228	0.2019	32 kbps	34 kbps	2
10.4.13.101	80	60397	80	11	348	19	6	248	5	729 bytes	144.312446	1.5781	9,276 bits/s	3,695 bits/s	3
10.4.13.101	80	60398	80	13	648	20	8	548	5	729 bytes	146.908484	1.5802	24 kbps	3,690 bits/s	5
10.4.13.101	80	60399	80	12	548	21	7	448	5	729 bytes	149.493160	1.5774	19 kbps	3,697 bits/s	4
10.4.13.101	80	60400	80	11	348	22	6	248	5	729 bytes	152.072387	1.5769	9,040 bits/s	3,698 bits/s	3
10.4.13.101	80	60401	80	83	7548	23	55	73 kB	28	2 kB	154.666218	1.5764	369 kbps	10 kbps	52
10.4.13.101	80	60402	80	84	7548	24	55	73 kB	29	2 kB	157.246773	1.5729	370 kbps	10 kbps	52
10.4.13.101	80	60403	80	82	7548	25	55	73 kB	27	2 kB	159.834326	1.5958	364 kbps	9,610 bits/s	52
10.4.13.101	80	60404	80	83	7548	26	55	73 kB	28	2 kB	162.434169	1.5929	365 kbps	9,898 bits/s	52
10.4.13.101	80	60405	80	10	248	27	5	822 bytes	5	880 bytes	165.035070	0.2140	30 kbps	32 kbps	2
10.4.13.101	80	60537	80	10	348	155	6	248	4	675 bytes	562.523507	1.5791	9,270 bits/s	3,419 bits/s	3
10.4.13.101	80	60538	80	13	648	156	8	548	5	729 bytes	565.113273	1.5762	24 kbps	3,700 bits/s	5
10.4.13.101	80	60539	80	12	548	157	7	448	5	729 bytes	567.701467	1.5785	19 kbps	3,684 bits/s	4
10.4.13.101	80	60540	80	10	248	158	6	248	4	675 bytes	570.293900	1.5860	8,988 bits/s	3,404 bits/s	3
10.4.13.101	80	60541	80	83	7548	159	55	73 kB	28	2 kB	572.885897	1.5893	366 kbps	9,921 bits/s	52
10.4.13.101	80	60542	80	84	7548	160	55	73 kB	29	2 kB	575.485652	1.5902	366 kbps	10 kbps	52
10.4.13.101	80	60543	80	84	7548	161	55	73 kB	29	2 kB	578.086991	1.5948	365 kbps	10 kbps	52
10.4.13.101	80	60544	80	80	7548	162	55	73 kB	25	2 kB	580.691931	1.5891	366 kbps	9,106 bits/s	52
10.4.13.101	80	60545	80	10	248	163	5	822 bytes	5	880 bytes	583.294437	0.2011	32 kbps	35 kbps	2

Shown in the screenshot above, is the IPv4 and TCP Conversation Statistics that happened throughout this PCAP. The client which is 10.4.13.101 is the only one communicating with everyone, and it is using HTTP (80), which is unencrypted communication, instead of HTTPS (443) which is the current modern standard.

The TCP tab of the Statistics Conversation, it shows repetitive connection to the same endpoints in similar sizes and multiple similar flows could indicate Command and Control (C2) communication.

The screenshot shows a Google search for "what does xloader usually steal". The AI Overview section provides a summary of XLoader malware, stating it is an infostealing malware that targets both Windows and macOS systems. Its primary objective is to harvest sensitive personal and financial data. It specifically steals the following information:

- Credentials & Passwords:** Usernames, passwords, and cookies saved in web browsers (e.g., Google Chrome, Firefox, Microsoft Edge, Opera).
- Email Data:** Account details and stored passwords from email clients (e.g., Microsoft Outlook, Thunderbird, Foxmail).
- FTP & Messaging Apps:** Login information stored in File Transfer Protocol (FTP) clients and various messengers.
- Keystrokes:** Uses built-in keylogging to record everything you type.
- Clipboard Data:** Steals whatever text or data you copy and paste.
- Screenshots:** Takes pictures of your active screen.

The search results section shows several articles from Cyber Defense Magazine, McAfee, and Acronis, all discussing XLoader malware and its capabilities.

Here we see after Googling what Xloader does, it targets Windows and MacOS systems and to harvest sensitive personal and financial data, which includes:

- Account Credentials
- Email Data
- FTP and Messages
- Keystrokes from Keyloggers
- Clipboard Data and Screenshots

Rafael Angelo Christianto

No.	Time	Source	Destination	Signal	Protocol	Length	Info
1791	2026-04-13 19:12:50.191468	10.4.13.101	104.21.62.145	HTTP	573	GET /vsr/?Y2N=Cfs_Ln&OJ=FE83ux0rseCwfyarKd/j125CHWNLg3hNAmxadb	
1810	2026-04-13 19:12:55.544250	10.4.13.101	3.33.251.168	HTTP	160	POST /t6bo/ HTTP/1.1 (application/x-www-form-urlencoded)	
1822	2026-04-13 19:12:58.112174	10.4.13.101	3.33.251.168	HTTP	281	POST /t6bo/ HTTP/1.1 (application/x-www-form-urlencoded)	
1835	2026-04-13 19:13:00.674353	10.4.13.101	3.33.251.168	HTTP	801	POST /t6bo/ HTTP/1.1 (application/x-www-form-urlencoded)	
1846	2026-04-13 19:13:03.238960	10.4.13.101	3.33.251.168	HTTP	112	POST /t6bo/ HTTP/1.1 (application/x-www-form-urlencoded)	
2036	2026-04-13 19:13:08.576360	10.4.13.101	3.33.251.168	HTTP	1033	POST /t6bo/ HTTP/1.1 (application/x-www-form-urlencoded)Continu	
2114	2026-04-13 19:13:11.196993	10.4.13.101	3.33.251.168	HTTP	1037	POST /t6bo/ HTTP/1.1 (application/x-www-form-urlencoded)Continu	
2206	2026-04-13 19:13:13.597268	10.4.13.101	3.33.251.168	HTTP	1041	POST /t6bo/ HTTP/1.1 (application/x-www-form-urlencoded)Continu	
2222	2026-04-13 19:13:16.030368	10.4.13.101	3.33.251.168	HTTP	578	GET /t6bo/?OJ=UEd4Kz2kywF3K8XbgQfPkq7ZMLC6PPRq4SbwEKI90ADx	
2235	2026-04-13 19:13:21.450787	10.4.13.101	47.76.53.129	HTTP	151	POST /liov/ HTTP/1.1 (application/x-www-form-urlencoded)	
2248	2026-04-13 19:13:24.209314	10.4.13.101	47.76.53.129	HTTP	272	POST /liov/ HTTP/1.1 (application/x-www-form-urlencoded)	
2262	2026-04-13 19:13:26.953254	10.4.13.101	47.76.53.129	HTTP	792	POST /liov/ HTTP/1.1 (application/x-www-form-urlencoded)	
2274	2026-04-13 19:13:29.713477	10.4.13.101	47.76.53.129	HTTP	103	POST /liov/ HTTP/1.1 (application/x-www-form-urlencoded)	
2354	2026-04-13 19:13:32.981206	10.4.13.101	47.76.53.129	HTTP	1056	POST /liov/ HTTP/1.1 (application/x-www-form-urlencoded)Continu	
2458	2026-04-13 19:13:35.736129	10.4.13.101	47.76.53.129	HTTP	1024	POST /liov/ HTTP/1.1 (application/x-www-form-urlencoded)Continu	
2562	2026-04-13 19:13:38.549127	10.4.13.101	47.76.53.129	HTTP	1028	POST /liov/ HTTP/1.1 (application/x-www-form-urlencoded)Continu	
2661	2026-04-13 19:13:41.307298	10.4.13.101	47.76.53.129	HTTP	1032	POST /liov/ HTTP/1.1 (application/x-www-form-urlencoded)Continu	
2699	2026-04-13 19:13:43.516081	10.4.13.101	47.76.53.129	HTTP	575	GET /liov/?Y2N=Cfs_Ln&OJ=Er6KntNF260+3ZVUJI0iX035zxr0aqYnNB5e5Z	
2712	2026-04-13 19:13:48.947992	10.4.13.101	18.201.116.200	HTTP	151	POST /t9hc/ HTTP/1.1 (application/x-www-form-urlencoded)	
2725	2026-04-13 19:13:51.618462	10.4.13.101	18.201.116.200	HTTP	272	POST /t9hc/ HTTP/1.1 (application/x-www-form-urlencoded)	
2739	2026-04-13 19:13:54.313182	10.4.13.101	18.201.116.200	HTTP	792	POST /t9hc/ HTTP/1.1 (application/x-www-form-urlencoded)	
2751	2026-04-13 19:13:56.992785	10.4.13.101	18.201.116.200	HTTP	103	POST /t9hc/ HTTP/1.1 (application/x-www-form-urlencoded)	
2831	2026-04-13 19:14:00.056123	10.4.13.101	18.201.116.200	HTTP	1056	POST /t9hc/ HTTP/1.1 (application/x-www-form-urlencoded)Continu	
2923	2026-04-13 19:14:02.731073	10.4.13.101	18.201.116.200	HTTP	1024	POST /t9hc/ HTTP/1.1 (application/x-www-form-urlencoded)Continu	
3018	2026-04-13 19:14:05.415677	10.4.13.101	18.201.116.200	HTTP	1028	POST /t9hc/ HTTP/1.1 (application/x-www-form-urlencoded)Continu	
3109	2026-04-13 19:14:08.081037	10.4.13.101	18.201.116.200	HTTP	1032	POST /t9hc/ HTTP/1.1 (application/x-www-form-urlencoded)Continu	
3133	2026-04-13 19:14:10.305055	10.4.13.101	18.201.116.200	HTTP	575	GET /t9hc/?OJ=V2h0aesSrvYFSIV20wEdu1shv8l0nvnvnlkKdEaorZkx6S1	

Frame 6: 592 bytes on wire (4656 bits), 592 bytes captured (4656 bits) on interface 0
Ethernet II, Src: Hewlett-Packard (08:00:02:1c:47:ae), Dst: Netgear_b6:93:f1 (20:00:0c:00:00:00:00:00) (0:8:0:2:0:0:0:0)
Internet Protocol Version 4, Src: 10.4.13.101, Dst: 23.80.89.64
Transmission Control Protocol, Src Port: 60377, Dst Port: 80, Seq: 1, Ack: 1, Len: 528
Hypertext Transfer Protocol

2026-04-13-XLoader-infection-traffic.pcap

Packets: 14271 · Displayed: 301 (2.1%)

This screenshot indicates a strong indication of XLoader where it does data exfiltration, multiple endpoints and does beaconing, with encoded POST data.

```
HTTP/1.1 404 Not Found
Server: nginx
Date: Mon, 13 Apr 2026 19:13:38 GMT
Content-Type: text/html
Content-Length: 548
Connection: close
Set-Cookie: server_name_session=04bb71a93ab983b7af21938806004b82; Max-Age=86400; httponly; path=/

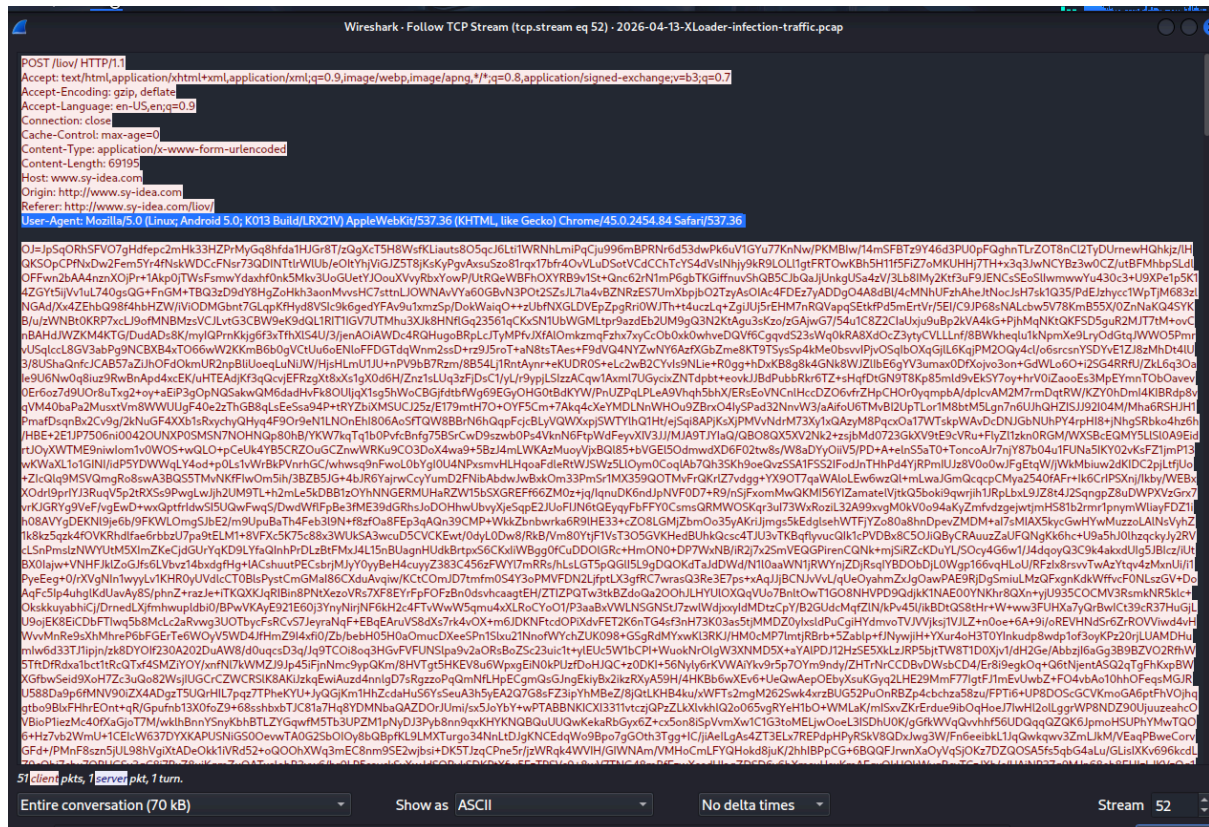
<html>
<head><title>404 Not Found</title></head>
<body>
<center><h1>404 Not Found</h1></center>
<hr><center>nginx</center>
</body>
</html>

<!-- a padding to disable MSIE and Chrome friendly error page -->
<!-- a padding to disable MSIE and Chrome friendly error page -->
<!-- a padding to disable MSIE and Chrome friendly error page -->
<!-- a padding to disable MSIE and Chrome friendly error page -->
<!-- a padding to disable MSIE and Chrome friendly error page -->
<!-- a padding to disable MSIE and Chrome friendly error page -->
```

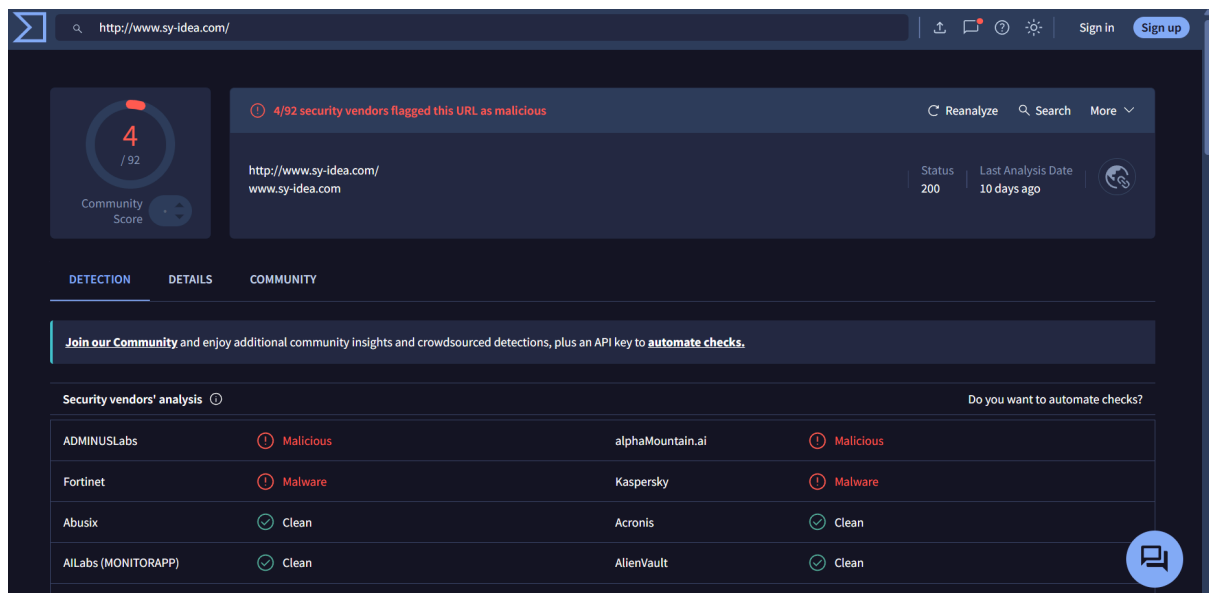
However after the POST request, it gets a 404 not found which sounds normal, but that means the server exists but the page does not. The server can be proven exist by being able to respond and give a cookie.

The question now is it goes to a random pages but it responds to a fake nginx page for a C2 communication, seen by the cookie. If it really was 404 Not Found, it should not give a cookie, but it gave a cookie for the beaconing.

Rafael Angelo Christianto



We see in the User-Agent field in the request, that it is not using any CLI tools like wget or curl, but it uses a legit browser in this case it is Mozilla Firefox



However the origin URL, or where it is going to when scanned with Virus Total, is flagged as malicious by 4 antivirus vendors.

However for the encoded message, I have a base64 decoder I have released into GitHub, all we have to do to use it to enter the encoded message inside of the encoded.txt file and run the [main.py](#) to get the hex, entropy and magic bytes.

```
ecoder/main.py"
[+] Loaded encoded.txt
[+] Base64 decoded successfully

[+] First 16 bytes (hex):
2694aa3918521553bb80775f7a973698
[-] Not zlib
[-] Not gzip

[+] Extracted strings:
b'!A0?X'
b'w=M)'
b')v0 '
b'y92K'
b'!lvV'
b'%b83'
b'P/THOR'
b'k7Doe'
b'%:i3'
b'tkj%e'
b'*`zoH'
b'i{P1'
b'|;F7'
b'^4{1'
b':q!#'
b'N69CW?D'
b'uv6M'
b'ByI8` '
b'2V<AB_9'
b'^Nv1'

[+] Entropy: 7.996524557637745

[+] Trying XOR brute (STRICT filter)...

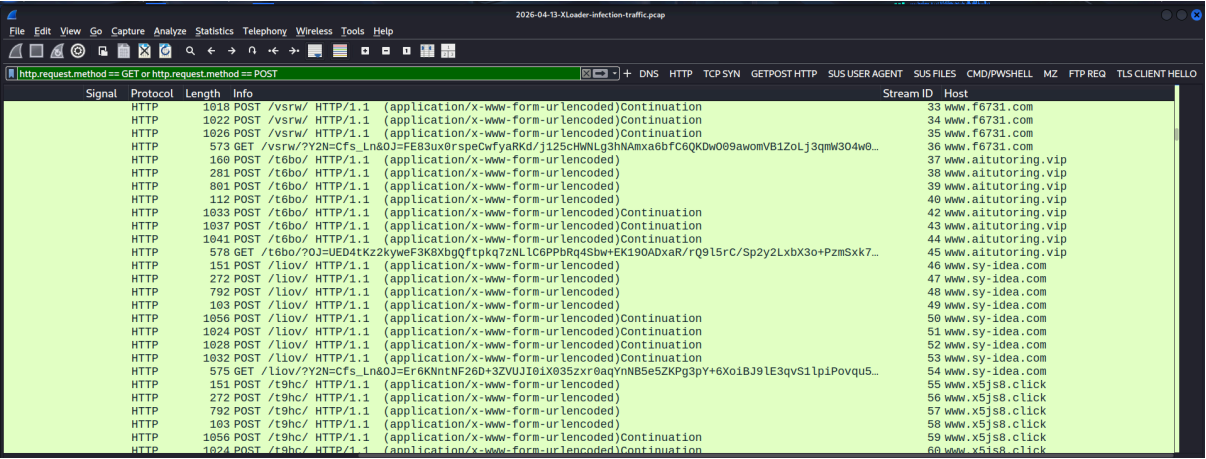
[KEY 4] 🔥 STRONG HIT:
b'OwhcMDg4'
```

So here is the result once I run the Python program I got this output where it is not zlib or gzip compressed, and no sign of known magic bytes such as:

- EXE (4D5A)
- ZIP (504B)
- GZIP (1F8B)

- ZLIB (789C)

But the strings obtained from it are very random and it has a really high entropy of 7.99, therefore data can be said to be very random, and it is encrypted. And the XOR brute filter catch might have been a false positive because it is a random string as well.



The screenshot shows a Wireshark capture of network traffic. The filter bar at the top is set to 'http.request.method == GET or http.request.method == POST'. The packet list on the left shows several HTTP requests. The packet details pane on the right shows the 'Host' field for each request, listing multiple domains: www.f6731.com, www.aitutoring.vip, www.sy-idea.com, and www.x5js8.click. The packet bytes pane at the bottom shows the raw data of the selected packet.

Signal	Protocol	Length	Info	Stream ID	Host
HTTP	1018 POST	/vsrw/	HTTP/1.1 (application/x-www-form-urlencoded)Continuation	33	www.f6731.com
HTTP	1022 POST	/vsrw/	HTTP/1.1 (application/x-www-form-urlencoded)Continuation	34	www.f6731.com
HTTP	1026 POST	/vsrw/	HTTP/1.1 (application/x-www-form-urlencoded)Continuation	35	www.f6731.com
HTTP	573 GET	/vsrw/?ZMcCfsLn&0J=FE83u&rspeCwfy&Rd/j125cHwLg3N&mx&8bfc6Q&Dw009awomVB1ZoLj3qmw304w0...		36	www.f6731.com
HTTP	160 POST	/t6bo/	HTTP/1.1 (application/x-www-form-urlencoded)	37	www.aitutoring.vip
HTTP	281 POST	/t6bo/	HTTP/1.1 (application/x-www-form-urlencoded)	38	www.aitutoring.vip
HTTP	801 POST	/t6bo/	HTTP/1.1 (application/x-www-form-urlencoded)	39	www.aitutoring.vip
HTTP	112 POST	/t6bo/	HTTP/1.1 (application/x-www-form-urlencoded)	40	www.aitutoring.vip
HTTP	1033 POST	/t6bo/	HTTP/1.1 (application/x-www-form-urlencoded)Continuation	42	www.aitutoring.vip
HTTP	1037 POST	/t6bo/	HTTP/1.1 (application/x-www-form-urlencoded)Continuation	43	www.aitutoring.vip
HTTP	1041 POST	/t6bo/	HTTP/1.1 (application/x-www-form-urlencoded)Continuation	44	www.aitutoring.vip
HTTP	578 GET	/t6bo/?0J=UED4TKz2kywEF3K8xbgqftpkq72NLc6PPbRq4Sbw+EK190ADxaR/rQ9l5rc/Sp2y2LxbX3o+PzmSxk7...		45	www.aitutoring.vip
HTTP	151 POST	/liov/	HTTP/1.1 (application/x-www-form-urlencoded)	46	www.sy-idea.com
HTTP	272 POST	/liov/	HTTP/1.1 (application/x-www-form-urlencoded)	47	www.sy-idea.com
HTTP	792 POST	/liov/	HTTP/1.1 (application/x-www-form-urlencoded)	48	www.sy-idea.com
HTTP	103 POST	/liov/	HTTP/1.1 (application/x-www-form-urlencoded)	49	www.sy-idea.com
HTTP	1056 POST	/liov/	HTTP/1.1 (application/x-www-form-urlencoded)Continuation	50	www.sy-idea.com
HTTP	1024 POST	/liov/	HTTP/1.1 (application/x-www-form-urlencoded)Continuation	51	www.sy-idea.com
HTTP	1028 POST	/liov/	HTTP/1.1 (application/x-www-form-urlencoded)Continuation	52	www.sy-idea.com
HTTP	1032 POST	/liov/	HTTP/1.1 (application/x-www-form-urlencoded)Continuation	53	www.sy-idea.com
HTTP	575 GET	/liov/?ZMcCfsLn&0J=Er6KmtmF26D+32VUJ0I0X035zxr&aqYmB5e5ZKpg3pY+6Xo1BJ9lE3qvS1lpIovqu5...		54	www.sy-idea.com
HTTP	151 POST	/t9hc/	HTTP/1.1 (application/x-www-form-urlencoded)	55	www.x5js8.click
HTTP	272 POST	/t9hc/	HTTP/1.1 (application/x-www-form-urlencoded)	56	www.x5js8.click
HTTP	792 POST	/t9hc/	HTTP/1.1 (application/x-www-form-urlencoded)	57	www.x5js8.click
HTTP	103 POST	/t9hc/	HTTP/1.1 (application/x-www-form-urlencoded)	58	www.x5js8.click
HTTP	1056 POST	/t9hc/	HTTP/1.1 (application/x-www-form-urlencoded)Continuation	59	www.x5js8.click
HTTP	1024 POST	/t9hc/	HTTP/1.1 (application/x-www-form-urlencoded)Continuation	60	www.x5js8.click

Additionally, from the screenshot above we see that the victim is not only connecting to 1 domain, it is connecting to many domains. It connects to multiple C2 instead of just 1 therefore it is harder to block and can be used for redundancy, and it is considered as a redundant C2 infrastructure. The domains visited seen by the screenshot above are:

- www.f6731.com
- www.aitutoring.vip
- www.sy-idea.com
- www.x5js8.click

Conclusion

To conclude, this traffic demonstrates typical Xloader behaviour. First what happens is that the victim visits a malicious site that redirects to another malicious site where the malware is delivered to the victim. Then, the victim connects to multiple C2 hosts using HTTP using encoded and high entropy payloads. The HTTP traffic also indicates POST requests, which could mean data exfiltration.

Indicators of Compromise (IoC)

Type	Indicator	Description
SHA256 hash	482a9c90793565dd1be62e4212bbc3af07bdaa6577296e3220c87e5c2aa2d070	Packet Capture hash
Victim IP address	10.4.13.101	Infected client
Domain	smartfavesden.shop	Initial infection from domain
Domain	istrakabiinw.info	Redirect from initial domain
Domain	f6731.com , aitutoring.vip, sy-idea.com , x5js8.click, ...	C2 infrastructure

MITRE ATT&CK Mapping

Technique	Reason
T1071.001 - Application Layer Protocol	HTTP C2 Communication
T1041 - Exfiltration over C2 Channel	Encrypted POST payloads
T1005 - Data from Local System	Credential and data theft
T1056.001 - Keylogging	One of Xloader's capabilities
T1115 - Clipboard Data	Clipboard theft
T1113 - Screen Capture	Screenshot capability

Detection Opportunities

- Monitor outbound HTTP POST requests with high entropy payloads
- Alert for beaconing to uncommon or malicious looking domains
- Detect 404 HTTP responses that still gives cookies.
- Alert connections with multiple domains that gives similar payloads.